



WEB SITE TRAFFIC THROTTLING USING ZERO TRUST IDENTITIES

DICK BROOKS

DICK@BUSINESSCYBERGUARDIAN.COM

BUSINESS CYBER GUARDIAN®

CONTROLLING TRAFFIC FLOW

- Business Cyber Guardian ZTBouncer for REST API's is a Zero Trust Gateway protecting HTTP REST API's from unwanted traffic and control (throttle) traffic based on a Zero Trust Identifier (ztdnaid)
- How does the ZTBouncer Gateway for REST Work:
 - Implements NIST Zero Trust Gateway Architecture (SP 800-207)
 - Runs as a process in front of the web server REST api's
 - Performs a zero trust check on a declared identity ([ztdnaid](#)) supplied by the caller as a query string parameter
 - Block parties that have not registered for access to the REST API website
 - Throttles user activity by [ztdnaid](#) using a maximum call rate factor, i.e. 5 calls in 5 minutes, adjustable in ZTBouncer properties file
 - Logging of all access requests, both trusted and untrusted attempts, suitable for SIEM input
 - Can disable access for a specific [ztdnaid](#) within seconds when trusted parties change

EXAMPLE DDR DATA

- ZTENTID DDR (Informational Posting Users) data examples, contains three concatenated string components separated by a delimiter:

- Owner Name (i.e. Pipeline Legal Name operating Information Posting Website)
- Subject Name identifier
- Unique identifier assigned to subject name (easy to remember PIN CODE)
- Example DDR data using / delimiter:

Snowboard Pipeline/BCG:Dick Brooks/570126254378

- ZTRESID (Informational Posting Website) data

- Zero Trust Domain Identifier(i.e. FQDN of website hosting Information Posting data)
- Resource Name identifier
- Unique identifier assigned to Resource (easy to remember PIN CODE)
- Example DDR data (note different delimiter ; due to URL):

Snowboardpipeline.com;SnowBoard Pipeline Informational Posting Website; <https://ipw.snowboardpipeline.com/>

ZTBOND DDR DATA

- ZTBOND Authorizing an Entity ZTENTID to Access a Resource ZTRESID

- Zero Trust Domain Identifier(MUST MATCH properties file "ZeroTrustDomain":
- Entity ZTENTID
- Resource ZTRESID
- Example DDR data (using , delimiter ; MUST match delimiter in properties file):

SnowboardPipeline.com, 03DAABB80DFC7FB83E3826B7B306CBA85E80F6A5E6FFF6801D60BF1DC9B976F5,
9BB7722139562FA03129A4016C6FE08F336D38B6C1E5D8B63E3B9254513E2977

NIST ARCHITECTURE – ZTBOUNCER IMPLEMENTATION

NIST SP 800-207

ZERO TRUST ARCHITECTURE

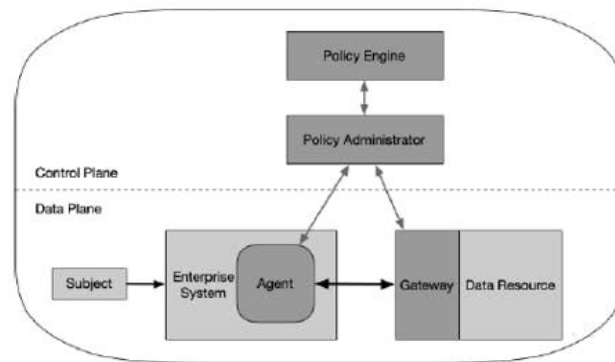
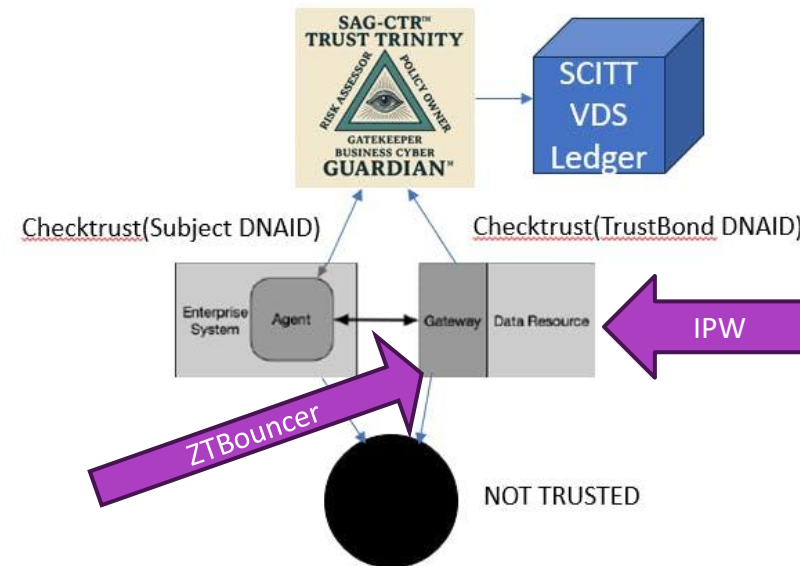


Figure 3: Device Agent/Gateway Model



SAG-CTR™ Gatekeeper is responsible for inserting and removing trusted object records in SAG-CTR™ Based on Registration Policies for three trusted object record types; Entity Trust DNAID, Resource Trust DNAID And a Zero Trust Bond DNAID record representing a Trust relationship between the two that can be revoked at any time preventing access. A ZT Bouncer Gateway performs a checktrust function requesting a “Trust Bond” record using Entity Trust Record and Resource Trust Record DNAIDs to lookup a Zero Trust Bond record in SAG-CTR™ to prevent an untrusted entity from accessing a Trusted resource. Both the Entity and Resource must be trusted before a Zero Trust Bond record (trusted object) is created in SAG-CTR™.

Copyright and all other rights reserved by Business Cyber Guardian™ under US patent 11,374,961

REQUIRED ROLES

- Registration Policy Owner – Snowboard Pipeline Company
 - Defines requirements for a ZT DNAID to be trusted and placed into SAG-CTR as a trusted object
 - ZTENTID – ZTDNAID for a named subject, i.e. remote user using DDR data
 - ZTRESID – ZTDNAID for a named Resource, i.e. Informational Posting Website using DDR data
 - ZTBOND – Authorizes a ZTENTID subject/entity to access a ZTRESID Resource, using DDR data
- Authorized Risk Assessor – Individual authorized by Snowboard Pipeline to submit Trust Declarations to SAG-CTR
 - Submit risk assessment evidence data to register a ZTENDID, ZTRESID, ZTBOND
- SAG-CTR Gatekeeper – Business Cyber Guardian
 - Enforces Snowboard Pipeline Registration Policy Owner policies by evaluating Risk Assessor evidence data against Registration Policies
- Informational Posting Users
 - Must supply their assigned ztdnaid as a query string parameter to access the Informational Posting website
 - ZTBouncer verifies that supplied ztdnaid is authorized in a ZTBOND record to access Snowboard Pipeline Information Posting Website
 - Failed verification results in session closure
 - ZTBouncer enforces usage rate using “maximum calls per time window” using setting in ZTBouncer properties file
 - Subjects that exceed maximum call rate are rejected with a response to try later

ZTBOUNCER PROPERTIES RATE THROTTLING

- {
- "ZTBouncerListenPort": 8080, - always assumes the hostname where ZTBouncer runs
- "BackendBaseURL": "https://ipw.snowboardpipeline.com", - This is the informational posting website
- "SAG_CTRLlookupAPIURL": "https://softwareassuranceguardian.com/SAGCTR_inquiry/getZTLabel?ProductID=",
- "ZeroTrustDomain": "<REDACTED>",
- "HTTPResourceDNAID": "<REDACTED>",
- "ZTBlogname": "ZTBouncerHTTP.log",
- "CertVerify": true,
- "delimiter": ",",
- "ZTQueryParamName": "ztdnaid",
- "TimeWindow": 1, - expressed in minutes
- "MaxCallRate": 1 – maximum number of calls allowed within TimeWindow minutes
- }

ZTDNAID REGISTRATION PROCESS

- A Party identified as an authorized Risk Assessor MUST be authorized by the Registration Policy Owner, Snowboard Pipeline
- Risk Assessor must be a valid/verified registered ZTENTID in SAG-CTR to submit trust declarations on behalf of Registration Policy Owner
- Performs a Risk assessment over a Digital DNA Record describing the Entity/Resource/Trust BOND
- Identifies the Label Type Declaration ID assigned to the Registration Policy Owner (Snowboard Pipeline) in evidence data
- Identifies type of Zero Trust entry ZTENTID, ZTRESID, ZTBOND
- Each “IPW registered user” is assigned a ZTDNAID by Snowboard Pipeline that matches a registered ZTENTID record
- Submit data to SAG-CTR Trust Queue using a digital chain of custody protocol
- SAG-CTR Gatekeeper assess submitted evidence data (Trust Queue entries) against Registration Owner Policies
 - Accepted entries are placed into the SAG-CTR Trust Registry as a trusted object
 - Rejected entries are recorded as rejected and are not placed into SAG-CTR
 - Risk Assessors are informed of the result using the email address on file for the ztdnaid associated with the Assessor

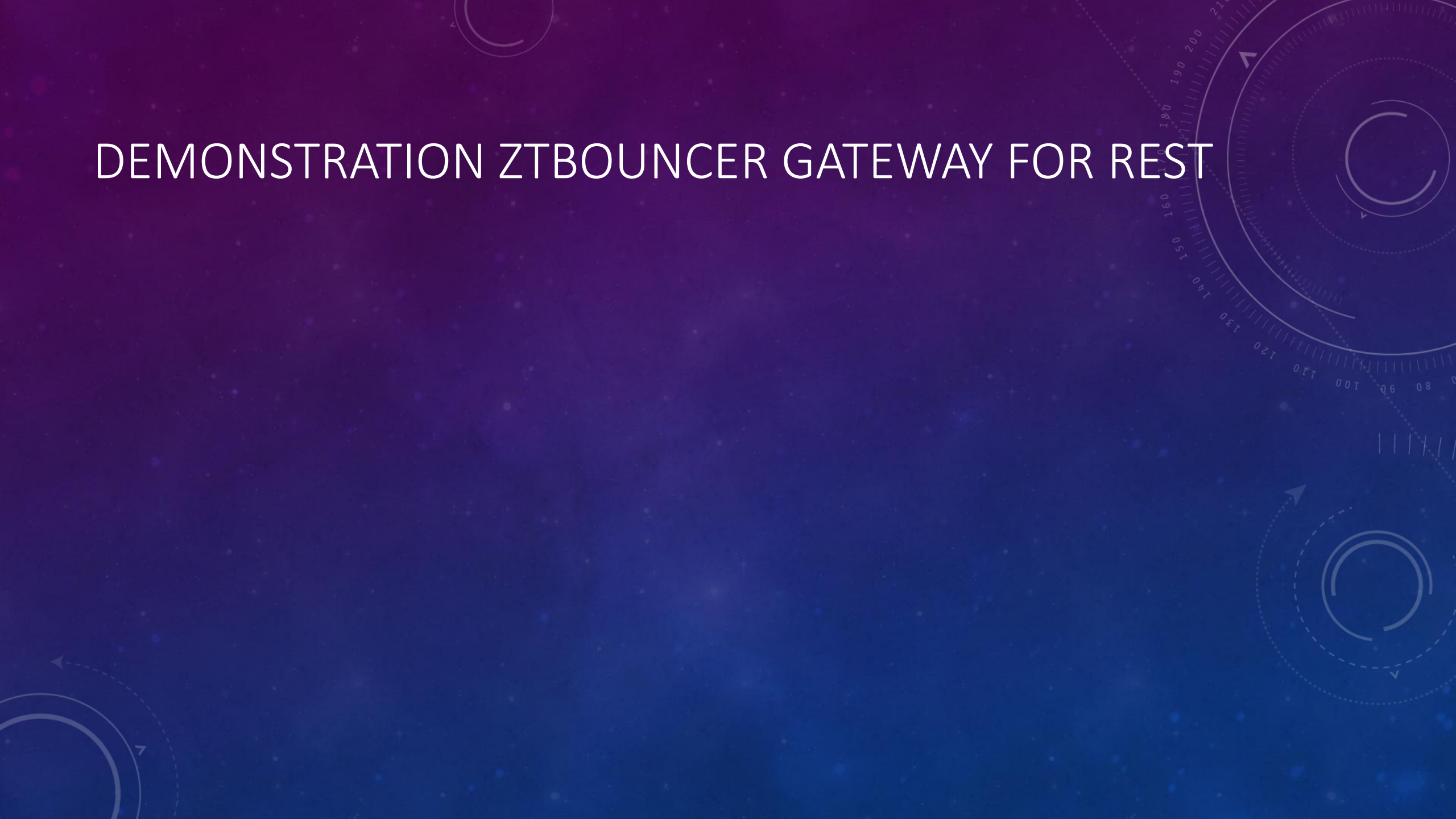
ZTDNAID VERIFICATION BEFORE ALLOWING ACCESS TO API

- An Informational Posting User issues a REST API call containing their ztdnaid as a query string parameter to the ZTBouncer Gateway protecting the Informational Posting Website
- The ZTBouncer Gateway checks for a ZTBOND record for the users ztdnaid and Information Posting Web Site ztdnaid to confirm that access is allowed
 - Three possible outcomes:
 - Zero Trust denied – there is no valid ZTBOND record for the user ztdnaid and Snowboard Pipeline Informational Posting website ztdnaid
 - Rate limiting warning if maximum call rate is exceeded
 - Snowboard Pipeline Informational Posting Website returns requested content to user

REPORTS

- SAG-CTR Registered ZTDNAID's for both Entities (web site users) and Resources (web site API's)
- SAG-CTR registered "Trust Bonds" that authorizes access to a Resource by a web site user using ztdnaids
- ZTBouncer Log files

DEMONSTRATION ZTBOUNCER GATEWAY FOR REST



CAVEATS

- All website content MUST use relative URL's in order to work with ZTBouncer Gateway products
- ZTBouncer maintains a list of trusted ztdnaids in the event of a network failure accessing SAG-CTR; verification is performed against this list of trusted ztdnaids when SAG-CTR network failures occur
- ZTBouncer processes should run behind a website product, like Apache httpd, where SSL/TLS certificates apply to all ZTBouncer Gateway processes and access
 - ZTBouncer Gateway is configured as an Apache pass through to the running ZTBouncer Gateway process running on its designated port, i.e. 8080 on the same host as the Apache httpd Server
- Informational Posting Website SHOULD only allow connections from the ZTBouncer Gateway IP address, all others are denied to control usage
- One hour to setup ZTBouncer Gateway in front of Informational Posting Website, PLUS
 - Customer setup (varies by customer)
 - ZTENTID, ZTRESID, ZTBOND DDR data risk assessment and registration into SAG-CTR (varies by customer)
 - Testing access, less than 30 seconds